

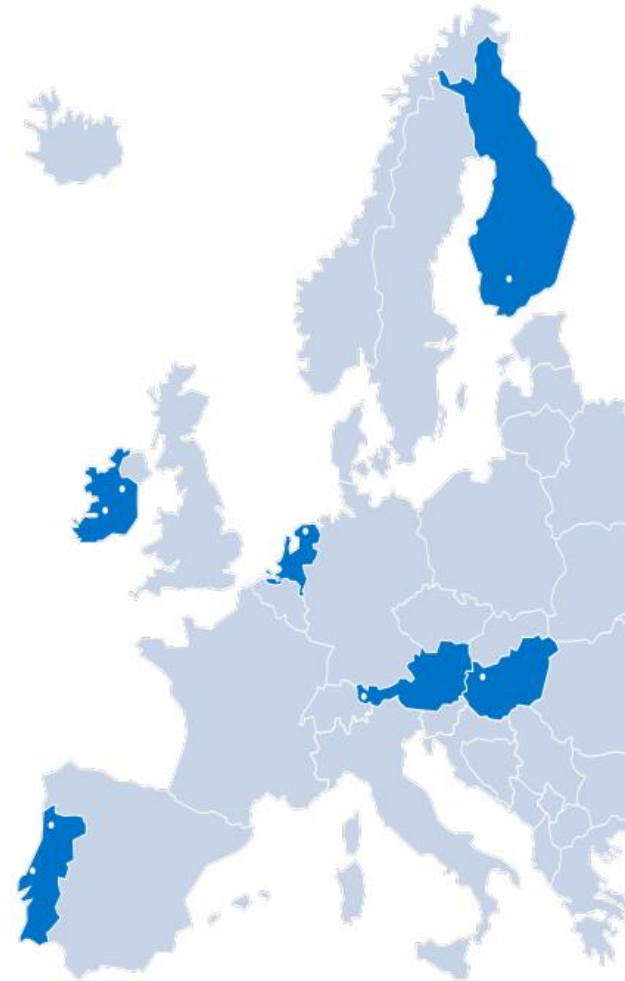
Writing the Penetration Test Report

Dr Ken Oakley



TUS

Technological University of the Shannon:
Midlands Midwest
Ollscoil Teicneolaíochta na Sionainne;
Lár Tíre Iarthar Láir.



Overview

- Why is the pen test report so important
- Scoping the pen test
- Report Writing
- Think about your audience
- What should and should not be included in the report
- The report writing process
 - Using templates
 - Planning and scoping the report
 - Collecting evidence during the testing activities
 - Risk and criticality of findings
 - Writing the first draft
 - Refining the report
- Report automation tools



Why is the pentest report so important?



PROVIDES A
DETAILED AND
COMPREHENSIVE
ANALYSIS OF THE
SYSTEM'S
VULNERABILITIES



IS INDEPENDENT OF
ENGINEERING AND
DEVELOPMENT
TEAMS



INFORMS DECISION
MAKERS ABOUT
RISKS AND
MITIGATIONS

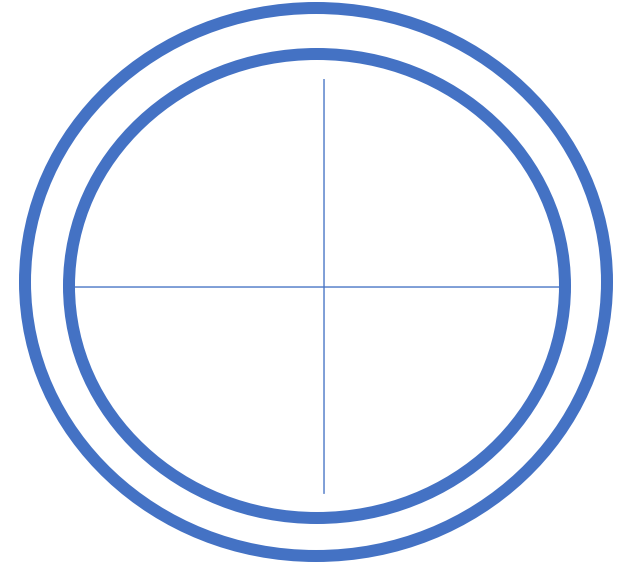


PROVIDES
JUSTIFICATION
FOR SPEND



IS A KEY TOOL IN
THE PREVENTION
OF EXPLOIT OR
BREACH

Scoping the pen test



Scoping is the process of defining the boundaries, objectives, deliverables, and limitations of the pen test to ensure clarity and focus.

Scoping the pen test

Types of test:

- Web application penetration testing
- Mobile application penetration testing
- API pentesting
- Pentesting IoT systems and connected objects
- Internal network pentesting
- Social engineering penetration testing

Scoping the pen test

What will you test

- IP Address ranges
- Specific servers or services
- Specific APIs
- Specific Databases

Scoping the pen test

What will you **not** test

- Production environments
- IP Address ranges
- Specific servers or services
- Specific APIs
- Specific Databases

Scoping the pen test

The Pen Test Scope is the record of what you are allowed to test under the written permission you have from the owner of the systems being tested

Never test anything you do not have written permission to test

Make sure you have your “Get out of jail free” statement

Why is Scoping so Important?

Example 1:

Ken carries out a pen test for company A. Shortly afterwards company A is hacked.

Example 2:

Ken carries out a pen test for company A. Shortly afterwards company B complains that it has been hacked as part of the pen test.

Report writing



Your audience



Executives

Very high level view (5 minute read)

Understand risk and criticality

Make decisions on how much risk to carry



Managers

Understand the remediations required

Develop (cost, scope, and schedule) the remediation project

Plan the remediation



Engineers

Need the technical detail of the findings

May have created the vulnerable code or system in the first place
Are responsible for fixing the issue

What's in a pen test report

Executive
Summary

Scope
Summary Data

Attack Surface
Mapping

Methodology

Findings

Remediation
actions

Risk Summary

Appendices

Report Template

Partially completed report

Different templates for different assessment types eg
web application vs network test vs IoT device test

Template makes reports more consistent

Libraries or stock language for certain parts

Static text for other parts

Report Template Contents

Title

Table of contents

Executive summary

Management summary

Overview

Attack methodology

Findings

Risks

Recommendations

Appendices

Executive Summary

1 Page approx.

Non technical

Often written last

Short sections

Bullet points

Read in less than 5 mins

Used to inform strategic business decisions

Input from customer contact

- Description and purpose
- Key findings/risk posture summary
- Most significant risks
- Recommendations
- Positive findings

See these reports for examples of exec summary

<https://pentestreports.com/reports/Leviathan/Leviathan%20Golden%20Frog%20Report%20-%20VyprVPN.html>

https://pentestreports.com/reports/NCCGroup/NCC_Group_Google_GOOG169_Report_2022-04-07_v1.2.html

<https://pentestreports.com/reports/Pentest-Limited/Report%20URI%20-%202020%20Penetration%20Test%20Report.html>

Consider the following scenario

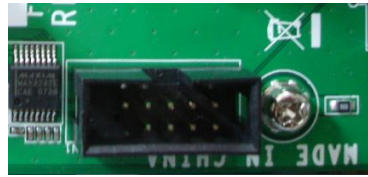
Excerpt from Executive Summary

The most concerning issues found during the assessment was that the firmware update function was vulnerable to authentication bypass. A malicious attacker could upload new firmware to the ECU that would allow attackers to gain direct access to the victim's braking system. Due to the design of the authentication system, this vulnerability would require a full product recall to remediate.

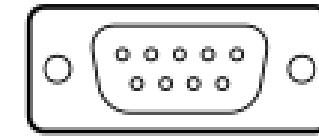
CVSSv3 score 7.8



Wireless



JTAG

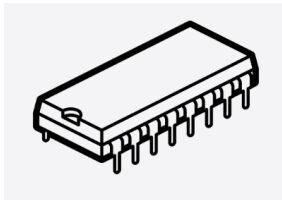


UART

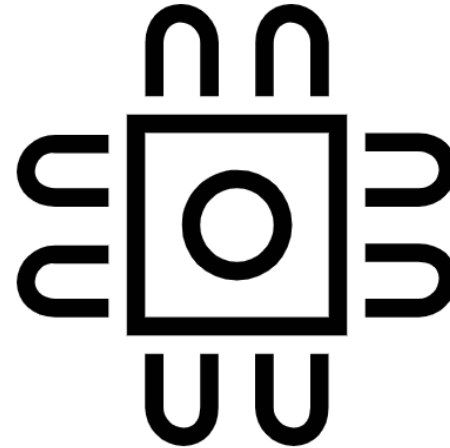
DE-9



Web Interface or API



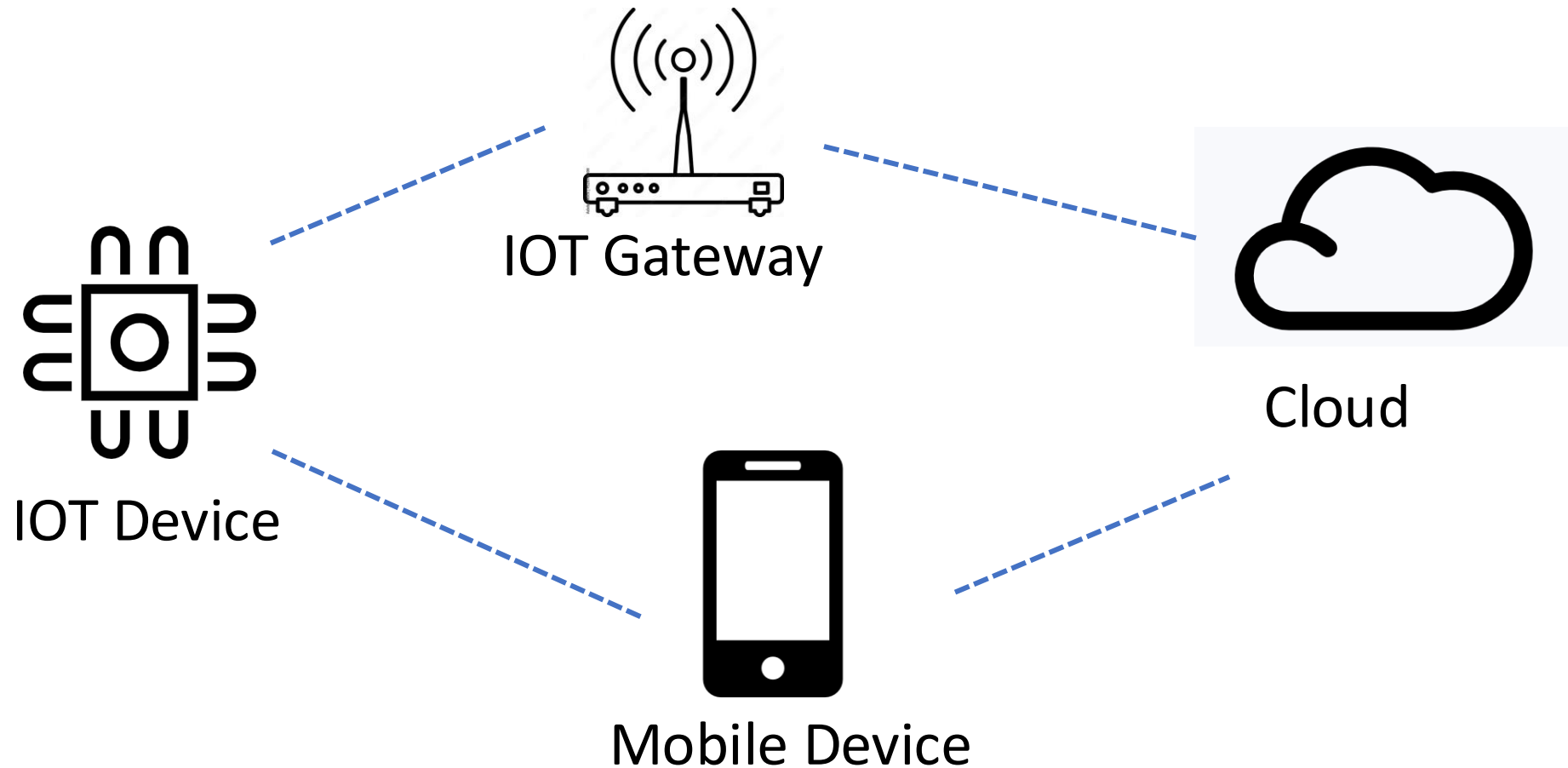
Direct Hardware Access



IOT Device

Attack
Surface
Mapping

Attack Surface Mapping



Scope of Testing...OWASP top 10

1 Weak Guessable,
or Hardcoded
Passwords

2 Insecure Network
Services

3 Insecure
Ecosystem
Interfaces

4 Lack of Secure
Update Mechanism

5 Use of Insecure
or Outdated
Components

6 Insufficient
Privacy Protection

7 Insecure Data
Transfer and
Storage

8 Lack of Device
Management

9 Insecure Default
Settings

10 Lack of Physical
Hardening

STRIDE

STRIDE is a model for identifying computer security threats developed by Microsoft

The threats are:

Spoofing

Tampering

Repudiation

Information disclosure

Denial of service

Elevation of privilege

Report Template Contents...Findings

Descriptive title for finding

- Eg “The server’s certificate is not valid for the hostname causing risk of unencrypted traffic”

Risk score

- Eg CVSS or DREAD

Location or URL

- <https://google-gruyere.appspot.com/359153759830157171792535919688096464740/snippets.gtl>

Description of finding

- One paragraph
- Use your library of finding templates

Steps to reproduce

- Include screenshots for evidence

Remediation

- Eg link to patch

References

- Eg links to more detail on the vulnerability

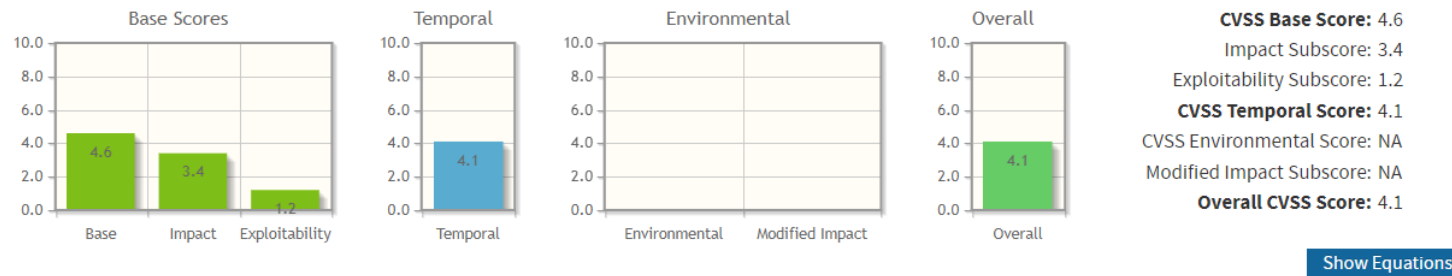
Metrics

- Severity: The severity of a vulnerability is a measure of the potential impact of exploitation.
- Likelihood: A measure of how probable it is that the vulnerability will be exploited in the near future.
- Criticality: A measure of the degree to which an organization depends on the asset or information, ie the consequence of failure of the asset
- Threat : Any circumstance or event with the potential to adversely impact organizational operations
- Risk : $\text{Likelihood} \times \text{Impact}$

Metrics...CVSS Severity

- Incorporates multiple factors to give an overall severity score

Ref <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>



CVSS v3.1 Vector

AV:N/AC:H/PR:L/UI:R/S:U/C:L/I:L/A:L/E:P/RL:W/RC:R

Base Score Metrics

Exploitability Metrics

Attack Vector (AV)*

Network (AV:N) Adjacent Network (AV:A) Local (AV:L) Physical (AV:P)

Attack Complexity (AC)*

Low (AC:L) High (AC:H)

Privileges Required (PR)*

None (PR:N) Low (PR:L) High (PR:H)

User Interaction (UI)*

None (UI:N) Required (UI:R)

Scope (S)*

Unchanged (S:U) Changed (S:C)

Impact Metrics

Confidentiality Impact (C)*

None (C:N) Low (C:L) High (C:H)

Integrity Impact (I)*

None (I:N) Low (I:L) High (I:H)

Availability Impact (A)*

None (A:N) Low (A:L) High (A:H)

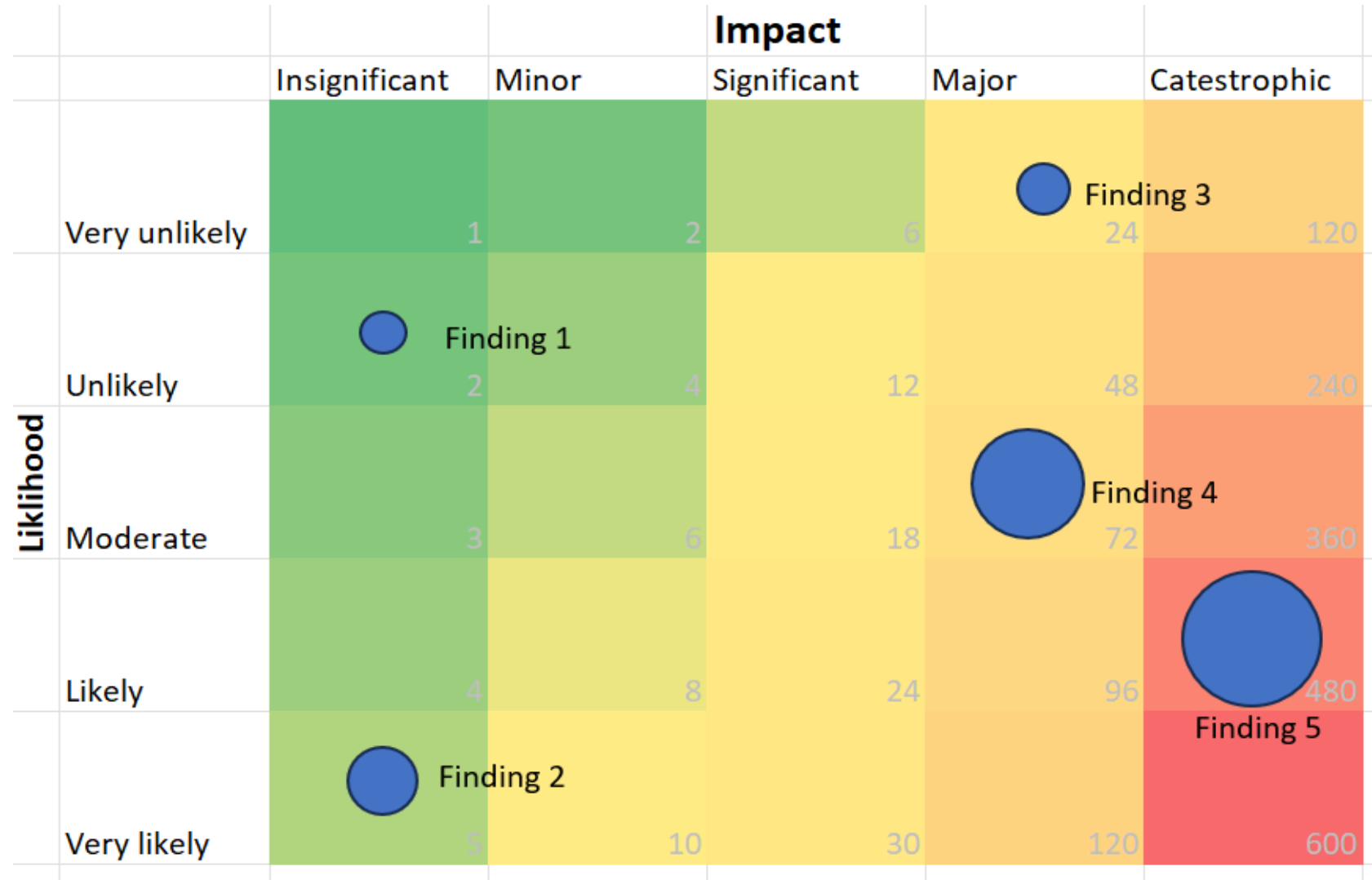
Risk Visualisation

- Using Graphics

		Impact				
		Insignificant	Minor	Significant	Major	Catestrophic
Likelihood	Very unlikely	1	2	6	24	120
	Unlikely	2	4	12	48	240
	Moderate	3	6	18	72	360
	Likely	4	8	24	96	480
	Very likely	5	10	30	120	600

Risk Visualisation

Using Graphics



A large orange circle is positioned on the left side of the slide, partially cut off by the edge. The word 'Methodology' is written in white text inside this circle.

Methodology

Clearly written set of steps to achieve the assessment goal

Must include screenshots

Anyone must be able to **reproduce** the results by following the methodology

Findings

Title

Stored Cross Site Scripting Vulnerability

CVSS v3 Score

8.9

CVSSv3.BaseScore

This is a very high risk vulnerability with a CVSSv3 score of 8.9

Findings

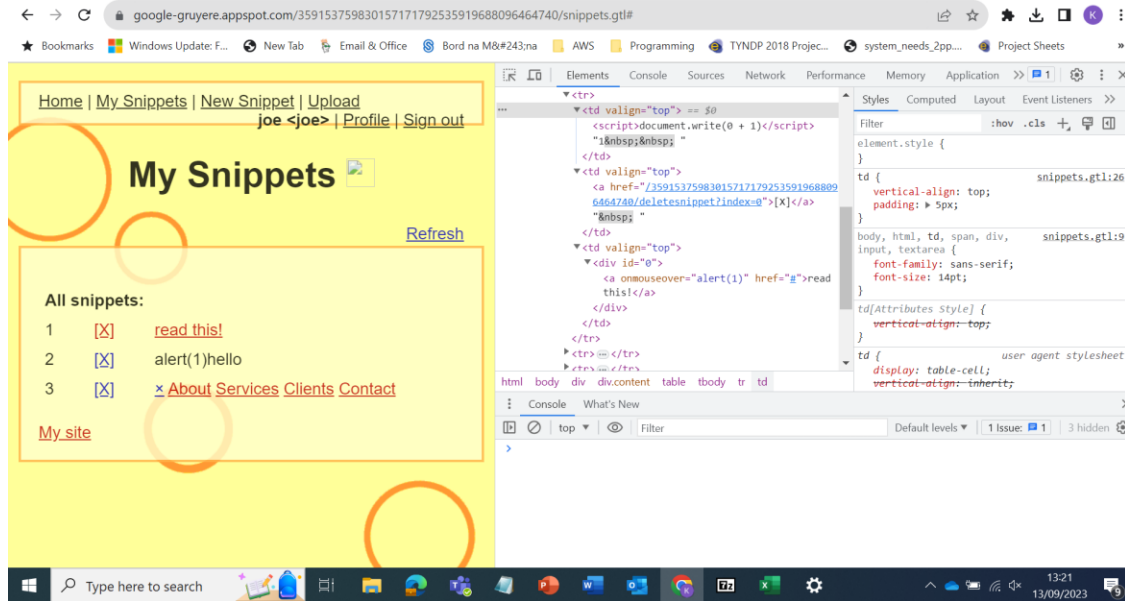
Background

“Cross-Site Scripting (XSS) attacks are a type of injection, in which malicious scripts are injected into otherwise benign and trusted websites. XSS attacks occur when an attacker uses a web application to send malicious code, generally in the form of a browser side script, to a different end user. Flaws that allow these attacks to succeed are quite widespread and occur anywhere a web application uses input from a user within the output it generates without validating or encoding it.

An attacker can use XSS to send a malicious script to an unsuspecting user. The end user’s browser has no way to know that the script should not be trusted, and will execute the script. Because it thinks the script came from a trusted source, the malicious script can access any cookies, session tokens, or other sensitive information retained by the browser and used with that site. These scripts can even rewrite the content of the HTML page”

Ref OWASP at <https://owasp.org/www-community/attacks/xss/>

Try Cross Site Scripting



<https://google-gruyere.appspot.com/part1>



<https://tryhackme.com/room/xss>

Findings

Recommendation

User controlled data should be sanitised when being rendered back to the user. The following sanitisation procedures should be considered

- Parse the input into an intermediate DOM structure, then rebuild the body as well-formed output.
- Use strict whitelists for allowed tags and attributes.
- Apply strict sanitization of URL and CSS attributes

Whenever possible it is preferable to use an already available known and proven HTML sanitizer such as <https://www.npmjs.com/package/sanitize-html>

Example Report

<https://pentestreports.com/reports/Pentest-Limited/Report%20URI%20-%202020%20Penetration%20Test%20Report.html>



<https://andersenlab.com/services/penetration-testing-services>



<https://qr.io/>

Review process

- Non technical review
- Technical review
- Make updates
- Can have multiple rounds of review
- Exec review and final sign off
- Reviews can improve the authors work
- Value the reviewers time
- Ensure the confidentiality of the report is maintained

What not to do

- Cut and paste from other reports as this may infringe copyright or may accidentally include data from other pentests
- Include vulnerabilities that might exist
- Work as a lone wolf...you are a team
- Include sentiment in the report
- Be defensive towards review
- Procrastinate.....write the report as you go

Automation

- Dradis https://dradisframework.com/ce/documentation/install_git.html
- Magic Tree https://www.gremwell.com/using_magictree_quick_intro
- Vulnreport
- Reporter <https://securityreporter.app/>

See <https://pentestreports.com/software/> for more examples

Appendix

- Tools Used
- Testing methodology
- Timeline
- Tool results raw data
- Scoring references eg CVSS
- Video demos

Example IoT Pentest reports

<https://rchase.com/downloads/momentum-iot-penetration-test-report.pdf>

https://pats.cs.cf.ac.uk/@archive_file?p=1710&n=final&f=1-report.pdf&SIG=58c7859d9081aeab1b51669856d50d0f0ad96b6506bcb19c8a24190cfaabb8a0